Educação Profissional Paulista

Técnico em **Desenvolvimento de Sistemas**

Secretaria da Educação

SÃO PAULO
GOVERNO DO ESTADO

Introdução à programação back-end e conceitos de desenvolvimento para web

Redes e segurança em desenvolvimento para web

Aula 2: Segurança em desenvolvimento para web

Código da aula: [SIS]ANO2C2B1S2A2

Secretaria da Educação
SÃO PAULO GOVERNO DO ESTADO

Mapa da Unidade 1 Componente 2

Introdução à programação back-end e conceitos de desenvolvimento para web

semana 1

Fundamentos de programação back-end

semana 2

Você está aqui!

Redes e segurança em desenvolvimento para web

semana 3

Bancos de dados

semana 4

APIs e serviços web

Mapa da Unidade 1 Componente 2

Introdução à programação back-end e conceitos de desenvolvimento para web

Você está aqui!

2

Redes e segurança em desenvolvimento para web

Aula 2: Segurança em desenvolvimento para web

Código da aula: [SIS]ANO2C2B1S2A2

Objetivos da aula

- Conhecer os princípios básicos de segurança em desenvolvimento para web.

Recursos didáticos

- Recurso audiovisual para exibição de vídeos e imagens.
- Lápis e caderno para anotações.

Duração da aula

50 minutos

Habilidades técnicas

- Relembrar conceitos básicos de redes e protocolos.

Habilidades socioemocionais

- Estimular a curiosidade ao aprender sobre os fundamentos de redes e protocolos e sua importância no desenvolvimento web.

Construindo o **conceito**

Segurança em desenvolvimento para web

A segurança em desenvolvimento para web é um aspecto crítico que envolve proteger as aplicações web contra ameaças e vulnerabilidades que podem comprometer a integridade, a confidencialidade e a disponibilidade dos dados e dos serviços.

Entender os riscos e adotar práticas de segurança robustas é essencial para criar aplicações que sejam confiáveis e seguras.

Vamos conhecer os tipos de cyber ataques que podem impactar um site ou uma aplicação?

Construindo o **conceito**

Segurança em desenvolvimento para web

1 SQL Injection (injeção de SQL)

É uma técnica em que um atacante insere ou "injeta" código SQL malicioso em uma entrada de campo de consulta com objetivo de manipular o banco de dados subjacente. Isso pode resultar em acesso não autorizado a dados, exclusão de informações, ou, até mesmo, controle total sobre o servidor de banco de dados.

2 Cross-site Scripting (XSS)

O XSS ocorre quando um atacante insere scripts maliciosos em páginas web vistas por outros usuários. Esses scripts podem ser usados para roubar cookies, sessões, ou redirecionar o usuário para sites maliciosos.

Exemplo: em um campo de comentários que não valida ou escapa as entradas corretamente, um atacante pode inserir um script JavaScript malicioso que será executado no navegador de outros usuários que visitarem a página.

Construindo o **conceito**

Segurança em desenvolvimento para web

3 Cross-site Request Forgery (CSRF)

Um ataque CSRF força um usuário autenticado a executar ações não desejadas em uma aplicação web na qual está autenticado, sem o seu consentimento. Isso pode ser feito enviando um link malicioso ou um formulário que é submetido automaticamente.

Exemplo: um link malicioso enviado por e-mail que, quando clicado pelo usuário autenticado, realiza uma ação no site onde o usuário está logado, como transferir fundos ou alterar configurações de conta.

4 Denial of Service (DoS) e Distributed Denial of Service (DDoS)

Ataques DoS e DDoS têm como objetivo tornar um serviço indisponível para seus usuários legítimos, geralmente sobrecarregando o servidor com uma quantidade massiva de requisições simultâneas.

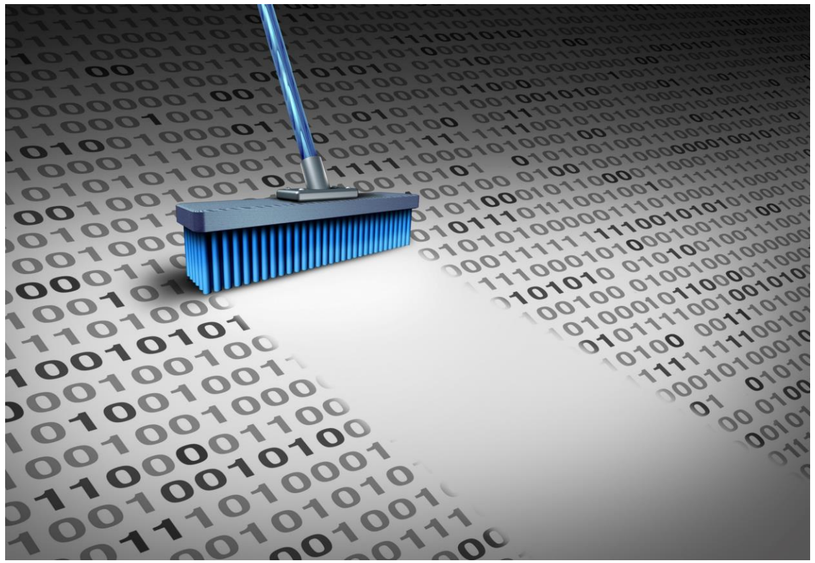
Exemplo: um ataque DDoS pode ser realizado utilizando uma rede de computadores comprometidos (botnet) para enviar um grande volume de tráfego para um servidor, esgotando seus recursos e derrubando o serviço.

Construindo o **conceito**

Boas práticas de segurança

Validação e sanitização de entrada
Todas as entradas de dados, sejam de usuários, APIs ou outras fontes externas, devem ser validadas e sanitizadas para garantir que sejam seguras. Isso impede que entradas maliciosas comprometam a segurança da aplicação.

Utilize métodos de validação e sanitização apropriados para o contexto. Por exemplo, se um campo deve conter apenas números, valide e rejeite qualquer entrada que contenha caracteres alfabéticos ou especiais.



© Getty Images

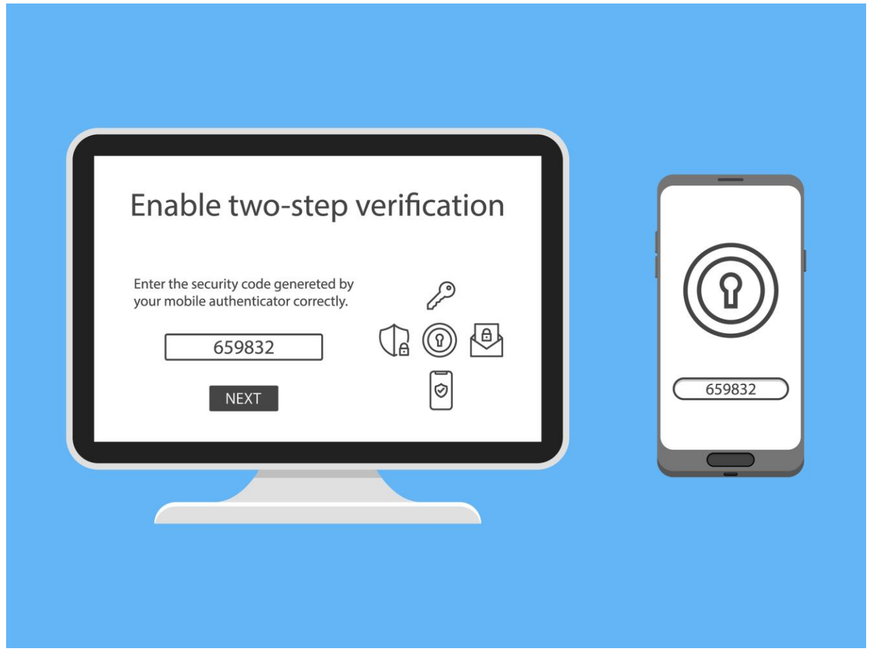
Construindo o **conceito**

Boas práticas de segurança

Uso de autenticação forte

Descrição: implementar autenticação forte é essencial para proteger as contas dos usuários. Isso inclui a utilização de senhas complexas, autenticação multifator (MFA) e limites para tentativas de login.

Prática: exigir que os usuários criem senhas complexas e fornecer suporte para autenticação multifator (como tokens SMS ou aplicativos autenticadores).



© Getty Images

Construindo o **conceito**

Boas práticas de segurança

O que é criptografia?

Criptografia é o processo de transformar dados legíveis (texto simples) em um formato ilegível (texto cifrado) para proteger a confidencialidade das informações durante a transmissão ou o armazenamento. Somente pessoas que têm a chave correta podem descriptografar e acessar os dados originais.

© Getty Images

Situação

Lidando com desafios de segurança em um projeto web

Você é um desenvolvedor recém-contratado em uma empresa de desenvolvimento de software e está participando do seu primeiro grande projeto web.

Durante uma revisão de código, você identificou que a aplicação tem vulnerabilidades críticas relacionadas à injeção de SQL e à exposição de dados sensíveis, o que pode colocar em risco a segurança dos usuários e da própria empresa. No entanto, ao apresentar suas preocupações para a equipe, alguns colegas minimizaram a gravidade das vulnerabilidades, argumentando que a aplicação já está próxima do lançamento e que as correções poderiam atrasar o cronograma.

Você se encontra em uma posição delicada: por um lado, sabe que essas vulnerabilidades podem ter consequências sérias, mas, por outro lado, você não quer ser visto como um obstáculo para o progresso do projeto, especialmente por ser novo na equipe. A empresa valoriza a segurança, mas também tem prazos rigorosos para cumprir.

Situação fictícia elaborada especialmente para o curso.

Ser
sempre +

Ação

- Como você lidaria com essa situação?

- Descreva como você comunicaria suas preocupações de forma construtiva, equilibrando a necessidade de segurança com os prazos do projeto. Considere como você pode colaborar com a equipe para encontrar uma solução que não comprometa a segurança, mas que também respeite os objetivos e os prazos da empresa.

Registro

Vamos fazer um **quiz**

O que é uma injeção de SQL?

- Inserção de código malicioso em uma consulta SQL.
- Envio de scripts por meio de campos de texto.
- Criação de sessões seguras para usuários.
- Uso de criptografia para proteger dados.

Registro

Vamos fazer um **quiz**

Qual é a principal diferença entre criptografia simétrica e assimétrica?

- Simétrica usa duas chaves, assimétrica usa uma.
- Simétrica é mais segura que assimétrica.
- Simétrica usa uma chave, assimétrica usa duas.
- Assimétrica não usa criptografia.

Registro

Vamos fazer um **quiz**

Qual é a prática recomendada para proteger dados sensíveis em trânsito?

- Armazenar em texto puro.
- Usar HTTPS.
- Utilizar HTTP sem criptografia.
- Enviar por e-mail.

O que nós **aprendemos hoje?**

Então, ficamos assim...

1. Compreendemos quais são os principais tipos de ataques existentes em aplicações para web.

2. Conhecemos conceitos de boas práticas de segurança para o desenvolvimento de aplicações publicadas na web.

3. Visualizamos o conceito de criptografia, que, atualmente, é essencial para a proteção dos sistemas existentes.

Saiba mais

Vimos como é importante a criptografia.

Então, que tal aprofundarmos o conhecimento nessa técnica para entendermos suas principais aplicações?

CÓDIGO FONTE TV. **Criptografia (guia básico para entender como funciona) // Dicionário do programador**. Disponível em: https://www.youtube.com/watch?v=qHFbuXpz7e4. Acesso em: 26 set. 2024.

Referências da aula

CÓDIGO FONTE TV. **Criptografia (guia básico para entender como funciona) // Dicionário do programador**. Disponível em: https://www.youtube.com/watch?v=qHFbuXpz7e4. Acesso em: 26 set. 2024.

LEMOS, G. Guia para pessoas desenvolvedoras Back-End 2021 – o que eu preciso saber?! **DEV**, 8 jan. 2021. Disponível em: https://dev.to/glaucia86/guia-para-pessoas-desenvolvedoras-back-end-2021-o-que-eu-preciso-saber-10c6. Acesso em: 26 set. 2024.

SANTANA, E. F. Z. Back-End: o que é e um guia para iniciar na área. **Alura**, 4 jul. 2024. Disponível em: https://www.alura.com.br/artigos/backend. Acesso em: 26 set. 2024.

Identidade visual: imagens © Getty Images.

Educação Profissional Paulista

Técnico em **Desenvolvimento de Sistemas**

Secretaria da Educação

SÃO PAULO
GOVERNO DO ESTADO